

CYBERSECURITY INCIDENT RESPONSE PLAYBOOKS

Capstone Project | Cybersecurity Program
Version 1.0 | March 2026 | CONFIDENTIAL

PHISHING
Playbook 1

RANSOMWARE
Playbook 2

DDoS ATTACK
Playbook 3

Table of Contents

Table of Contents2

Executive Summary4

Playbook 1: Phishing Attack Response.....5

 1.1 Incident Identification5

 Triggers & Indicators of Compromise (IOCs)5

 Phishing Sub-Types5

 1.2 Incident Response Phases5

 1.3 Roles and Responsibilities6

 1.4 Communication Strategy.....6

 Internal Communications.....6

 External Communications7

 1.5 Success Metrics7

Playbook 2: Ransomware Infection Response.....8

 2.1 Incident Identification8

 Triggers & Indicators of Compromise (IOCs)8

 Ransomware Attack Lifecycle8

 2.2 Incident Response Phases8

 2.3 Roles and Responsibilities9

 2.4 Communication Strategy..... 10

 Crisis Communication Principles..... 10

 Stakeholder Communication Matrix 10

 2.5 Ransom Decision Framework..... 10

 2.6 Success Metrics..... 11

Playbook 3: DDoS Attack Response 12

 3.1 Incident Identification 12

 DDoS Attack Types 12

 Triggers & IOCs..... 12

 3.2 Incident Response Phases 12

 3.3 Roles and Responsibilities 13

 3.4 Communication Strategy..... 14

 During Active Attack — Communication Protocol 14

 3.5 Success Metrics 14

Design Rationale & Benefits 15

 4.1 Design Philosophy 15

 4.2 Key Design Choices..... 15

 Tiered Severity Classification 15

 Phase-Based Response with Time Targets 15

 RACI-Aligned Role Definitions 15

 Communication Matrix Design 15

4.3 Expected Organizational Benefits	15
Post-Incident Review Template	17
Section 1: Incident Overview	17
Section 2: Timeline of Events	17
Section 3: Impact Assessment.....	17
Section 4: Root Cause Analysis.....	18
Section 5: Response Evaluation	18
Section 6: Lessons Learned	18
Section 7: Corrective Action Plan	19
Section 8: Playbook Update Recommendations	19
Section 9: Sign-Off	19
Appendix: Quick Reference Cards	20
A. Phishing — First 30 Minutes Checklist	20
B. Ransomware — Immediate Actions (First 15 Minutes)	20
C. DDoS — First 10 Minutes Checklist	20
D. Useful Tools & Resources	20

Executive Summary

This document presents three comprehensive Incident Response (IR) Playbooks developed for organizational cybersecurity resilience. Each playbook provides structured, actionable guidance for detecting, containing, eradicating, and recovering from a specific class of security incident.

The three scenarios addressed are:

- **Playbook 1: Phishing Attack Response**
- **Playbook 2: Ransomware Infection Response**
- **Playbook 3: Distributed Denial of Service (DDoS) Attack Response**

These playbooks are aligned with the NIST SP 800-61 Incident Handling Guide and incorporate industry best practices for cross-functional coordination, stakeholder communication, and continuous improvement. They are designed to minimize mean time to detect (MTTD) and mean time to resolve (MTTR) while ensuring regulatory compliance and preserving evidence for forensic review.

SEVERITY CLASSIFICATION

Critical: Immediate escalation required, executive notification within 1 hour. High: Response team activated within 2 hours. Medium: Investigation within 8 hours. Low: Review within 24 hours.

Playbook 1: Phishing Attack Response

Incident Type: Phishing / Spear Phishing / Business Email Compromise (BEC) | **Default Severity:** HIGH

1.1 Incident Identification

Triggers & Indicators of Compromise (IOCs)

The following events should trigger activation of this playbook:

- User reports a suspicious email requesting credentials, wire transfers, or sensitive data
- Email gateway alerts flagging links to known phishing domains or malicious attachments
- SIEM alert: multiple failed login attempts following email delivery to a user
- User accounts exhibiting anomalous behavior (login from new geography, mass email forwarding rules created)
- Anti-virus or EDR solution detects macro execution from an Office document attachment
- Reports of credential compromise or unauthorized access to internal systems

Phishing Sub-Types

Sub-Type	Description	Additional Risk
Mass Phishing	Untargeted bulk email lure	Credential harvesting, malware delivery
Spear Phishing	Targeted attack on specific employees	High success rate; targeted data theft
Whaling	Targeting C-suite executives	Financial fraud; strategic data loss
BEC / CEO Fraud	Impersonating executives for wire transfer requests	Direct financial loss; regulatory breach
Vishing / Smishing	Voice or SMS-based phishing	Bypasses email controls

1.2 Incident Response Phases

Phase	Actions	Timeline
DETECT	• Monitor email security gateway (e.g., Proofpoint, Mimecast) alerts • Review SIEM correlation rules for phishing indicators • Collect forwarded suspicious email from users • Query email logs for sender domain and identify all recipients • Analyze URLs with a sandbox (e.g., VirusTotal, Any.run) • Check for credential access attempts in IAM/Active Directory logs	0 – 30 min
CONTAIN	• Quarantine the phishing email across all affected mailboxes • Block malicious sender domain and URLs at email gateway and web proxy • Reset credentials for any users who clicked links or submitted data • Enforce MFA re-enrollment for affected accounts	30 min – 2 hrs

	- Disable email forwarding rules created during the attack window - Isolate endpoint if malware payload was executed	
ERADICATE	- Purge all instances of the phishing email using admin email tooling - Conduct full EDR scan on endpoints that interacted with attachments - Remove any persistence mechanisms (auto-forward rules, OAuth tokens granted) - Revoke all active sessions for compromised accounts - Conduct threat hunt for lateral movement from compromised credentials - Review audit logs for data access or exfiltration during the attack window	2 – 8 hrs
RECOVER	- Restore locked or compromised accounts with new credentials - Confirm MFA is active and functioning for all affected users - Conduct post-incident security awareness communication to all staff - Update email filtering rules and blocklists - Review and tune SIEM detection rules based on new IOCs - Validate no residual unauthorized access remains	8 – 24 hrs

1.3 Roles and Responsibilities

Role	Responsibility	Contact
Incident Commander	Oversees overall response; makes escalation decisions; authorizes containment actions	<i>CISO / Security Manager</i>
Technical Lead (IR)	Leads forensic investigation; coordinates containment and eradication	<i>Senior Security Analyst</i>
Email Administrator	Quarantines emails; manages gateway rules; pulls delivery logs	<i>IT Operations</i>
Identity & Access Mgmt	Resets passwords; enforces MFA; reviews account activity	<i>IAM/Directory Services Team</i>
Endpoint Security	Scans and isolates affected endpoints; reviews EDR telemetry	<i>Endpoint Security Team</i>
Communications Lead	Drafts user notifications; coordinates with PR if needed	<i>Corporate Communications</i>
Legal / Compliance	Assesses regulatory notification obligations (GDPR, HIPAA, etc.)	<i>Legal Department</i>
Help Desk	First point of contact for user reports; triages initial reports	<i>IT Help Desk</i>

1.4 Communication Strategy

Internal Communications

Timeframe	Audience	Channel	Message
0 – 30 min	Incident Commander, Technical Lead	Slack/Teams (IR channel)	Initial triage findings; severity assessment
30 min – 1 hr	CISO, IT Management	Phone / Encrypted Email	Incident confirmed; containment initiated
1 – 2 hrs	All Staff (if widespread)	Internal Email / Intranet	Alert: Do not click links in emails from [sender]; report suspicious emails to security@
2 – 4 hrs	HR, Finance (if BEC)	Secure Meeting	BEC financial exposure; freeze any pending wire transfers
24 hrs	All stakeholders	IR Status Report	Resolution summary; corrective actions underway

External Communications

- Regulatory bodies (e.g., ICO, SEC, HHS) if PII or financial data was confirmed compromised — within required notification windows
- Cyber insurance carrier — notify within 24-48 hours of confirmed incident
- Affected third parties or customers — after legal review, per contractual obligations
- Law enforcement (FBI IC3, CISA) — if financial fraud or nation-state threat actor suspected

1.5 Success Metrics

Metric	Target / Threshold	Owner
Time to Detect (TTD)	< 30 minutes from email delivery	<i>Technical Lead</i>
Email quarantine completeness	100% of phishing emails removed from all mailboxes	<i>Email Administrator</i>
Credential reset completion	100% of exposed accounts reset within 2 hours	<i>IAM Team</i>
Malware-free endpoint confirmation	100% EDR scan completion within 8 hours	<i>Endpoint Security</i>
User communication sent	Within 2 hours of confirmation	<i>Communications Lead</i>
Time to Full Resolution (MTTR)	< 24 hours	<i>Incident Commander</i>
Repeat phishing click rate (30-day post-incident)	< 5% in simulated phishing test	<i>Security Awareness Lead</i>

Playbook 2: Ransomware Infection Response

Incident Type: Ransomware / Crypto-Malware / Data Extortion | **Default Severity:** CRITICAL

CRITICAL WARNING

Do NOT pay the ransom without CISO, Legal, and executive approval. Payment does not guarantee recovery, may fund criminal organizations, and may violate OFAC sanctions regulations.

2.1 Incident Identification

Triggers & Indicators of Compromise (IOCs)

- Files renamed with unfamiliar extensions (e.g., .locked, .encrypted, .STOP, .WNCRY)
- Ransom note files (README.txt, HOW_TO_DECRYPT.html) appearing on file shares
- EDR / AV alerts for known ransomware families (LockBit, BlackCat/ALPHV, Cl0p, Hive, etc.)
- Sudden spike in file modification events across network shares (SIEM alert)
- User reports inability to open files; applications crashing
- Unusual outbound network traffic to Tor nodes or C2 infrastructure
- Volume Shadow Copy (VSS) deletion commands observed in process logs
- Backup systems unreachable or backup files deleted/encrypted

Ransomware Attack Lifecycle

Stage	Attacker Activity
Initial Access	Phishing / RDP / Vuln exploit
Execution & Persistence	Payload dropped; scheduled tasks; registry keys
Privilege Escalation	Lateral movement; credential dumping; admin access gained
Defense Evasion	AV disabled; VSS deleted; logs cleared
Exfiltration	Data stolen prior to encryption for double extortion
Encryption	Files encrypted; ransom note deployed; network share traversal

2.2 Incident Response Phases

Phase	Actions	Timeline
DETECT	- Confirm ransomware alert via EDR/SIEM; identify affected host(s) and file share scope - Identify the ransomware family using note text, file extension, or ID Ransomware tool - Determine patient zero (initial infected system) through log correlation - Assess network share encryption scope: how many shares/files affected? - Check backup system integrity — are backups accessible and unencrypted?	0 – 15 min

	Identify any data exfiltration activity in prior 48-72 hours (double extortion check)	
CONTAIN	- IMMEDIATE: Isolate infected systems from the network (disable NIC, segment VLAN) - Disable affected user accounts and service accounts with compromised credentials - Block known C2 IPs/domains at firewall and web proxy - Suspend access to network file shares from infected subnets - Preserve memory image and disk image of patient zero before remediation - Alert IT Operations: initiate network segmentation protocol - Notify backup team: take offline backup snapshots immediately; verify integrity	0 – 30 min
ERADICATE	- Conduct full forensic investigation of patient zero and lateral movement path - Identify and remove all ransomware artifacts: payloads, persistence mechanisms, tools - Reset all compromised credentials across the environment - Patch the vulnerability or misconfiguration used as initial access vector - Harden RDP, disable unused ports, review firewall rules - Validate VSS restoration feasibility for unencrypted data recovery - Rebuild or reimage compromised systems from known-good baselines	Hours – Days
RECOVER	- Restore data from last known-good backups (offline/immutable backups preferred) - Validate restored data integrity; test application functionality - Gradually restore network connectivity with enhanced monitoring - Implement EDR containment policies before returning systems to production - Deploy improved detection rules for the identified ransomware family - Conduct executive briefing on full impact and recovery status - Monitor restored systems for re-infection for a minimum of 30 days	Days – Weeks

2.3 Roles and Responsibilities

Role	Responsibility	Contact
Incident Commander	Directs all response activities; crisis decision-making; ransom escalation decision	<i>CISO / CIO</i>
Executive Sponsor	Approves ransom payment decisions; engages cyber insurance; regulatory interface	<i>CEO / CFO</i>
IR Technical Lead	Forensic investigation; malware analysis; eradication coordination	<i>Senior IR Analyst / MSSP</i>

Network Engineer	Network segmentation; firewall rule changes; C2 blocking	<i>Network Operations</i>
Systems Administrator	System isolation; backup restoration; system rebuilds	<i>IT Operations</i>
Backup Administrator	Assesses backup integrity; initiates restore procedures	<i>Backup/DR Team</i>
Legal / Compliance	Ransom payment legality (OFAC sanctions); regulatory breach notifications	<i>General Counsel / Legal</i>
Communications Lead	Manages internal and external communications; media inquiries	<i>PR / Comms Team</i>
Cyber Insurance Liaison	Engages insurer; coordinates coverage assessment and forensic support	<i>Risk Management</i>

2.4 Communication Strategy

Crisis Communication Principles

- Use out-of-band communication channels (mobile phones, personal email) — corporate email may be compromised
- Operate on a need-to-know basis initially; avoid broad announcements before containment
- Designate a single spokesperson for any external communications
- Document all communications with timestamps for legal and insurance purposes

Stakeholder Communication Matrix

Timeframe	Audience	Channel	Key Message
0 – 15 min	IR Team, CISO	Phone / Signal	Ransomware confirmed; isolation initiated; war room convened
15 – 30 min	C-Suite, Board (if critical)	Phone	Business impact assessment; critical systems status; recovery timeline
1 – 2 hrs	All Staff	SMS / Phone Tree	Systems outage underway; do not attempt to access encrypted files; IT is investigating
2 – 4 hrs	Cyber Insurance Carrier	Phone + Email	Formal incident notification; request forensic support if needed
4 – 24 hrs	Regulators (as applicable)	Certified/Encrypted Email	Incident notification per GDPR/HIPAA/SEC reporting windows
24 – 48 hrs	Customers / Partners	Coordinated via Legal	If data breach confirmed; notification per contractual obligations
Daily	Executive Leadership	War Room Briefing	Recovery progress updates; resource needs; decision points

2.5 Ransom Decision Framework

RANSOM PAYMENT DECISION

Paying ransom is a last resort. The following criteria must ALL be evaluated before any payment decision is made by executive leadership and legal counsel.

1. **Confirm backup restoration is NOT viable (backups encrypted/destroyed/insufficient)**
2. Assess OFAC compliance — verify the threat actor group is not on a sanctions list
3. Engage cyber insurance carrier — confirm coverage for ransom payment
4. Obtain legal opinion on regulatory and legal implications of payment
5. Negotiate via a professional ransomware negotiation firm
6. Document full decision-making process with executive sign-off

2.6 Success Metrics

Metric	Target / Threshold	Owner
Time to Isolation (TTI)	< 30 minutes from detection	IR Technical Lead
Backup restoration success rate	> 95% of critical data recovered	Backup Administrator
Systems returned to production	100% within defined RTO	IT Operations
Unpatched vulnerability remediation	100% within 72 hours post-incident	Technical Lead
Data exfiltration confirmed / scope	Documented within 48 hours	Forensic Analyst
Regulatory notification deadline met	100% compliance with legal windows	Legal / Compliance
MTTR (critical systems)	Per Business Continuity Plan RTO	Incident Commander

Playbook 3: DDoS Attack Response

Incident Type: Distributed Denial of Service (DDoS) / Application Layer Attack | **Default Severity:** HIGH – CRITICAL

3.1 Incident Identification

DDoS Attack Types

Attack Type	Description	Detection Method
Volumetric (Layer 3/4)	Floods bandwidth with UDP/ICMP/TCP traffic; DNS amplification	NetFlow anomaly; bandwidth spike alerts
Protocol Attacks	SYN floods, fragmented packets — exhausts connection tables	Firewall/IPS alerts; TCP state table exhaustion
Application Layer (L7)	HTTP GET/POST floods targeting web app logic	WAF alerts; abnormal request rates per URL
Reflection/Amplification	Spoofed source IPs used to amplify attack traffic via DNS/NTP	Traffic analysis; upstream ISP alerts
Multi-Vector Attack	Simultaneous volumetric + application layer attack	Correlation of multiple alert types

Triggers & IOCs

- Network monitoring alerts: sustained traffic spike exceeding baseline by 200%+
- Web application monitoring: error rate spike (5xx errors), latency > 2x baseline
- ISP or CDN provider sends DDoS alert notification
- NOC/Help desk receives flood of reports: website/service unreachable
- Firewall or load balancer CPU/memory exceeds 90% threshold
- Anomalous geographic traffic distribution (majority from unexpected countries)

3.2 Incident Response Phases

Phase	Actions	Timeline
DETECT	• Confirm DDoS via network monitoring (NetFlow/IPFIX), WAF, and ISP notification • Classify attack type: volumetric, protocol, or application layer • Identify targeted IP addresses, ports, and services • Measure attack bandwidth and packet rate (Gbps/PPS) • Assess business impact: which services are degraded or down? • Determine if DDoS is a diversion tactic for a concurrent intrusion	0 – 10 min
CONTAIN	• Activate DDoS mitigation service (e.g., Cloudflare Magic Transit, Akamai Prolexic, AWS Shield) • Implement upstream traffic scrubbing with ISP / upstream provider • Block source IP ranges at perimeter firewall (if volumetric with concentrated sources)	10 – 60 min

	• Enable rate limiting on web application firewall (WAF) for L7 attacks • Implement geoblocking for attack-originating regions if acceptable to business • Enable challenge pages (CAPTCHA / JS challenge) via CDN for web services • Scale resources horizontally if using cloud infrastructure (auto-scaling groups)	
ERADICATE	• Work with ISP to null-route or black hole specific attack traffic • Tune WAF and IPS rules based on attack traffic signatures • Update BGP routing to redirect traffic through scrubbing centers • Remove temporary IP blocks that may affect legitimate users • Validate mitigation effectiveness through traffic monitoring • Conduct full review of firewall rules to remove temporary emergency rules	Ongoing during attack
RECOVER	• Restore full service once attack traffic has subsided; monitor for re-attack • Validate application performance and database health • Review and document effective vs. ineffective mitigation measures • Evaluate and activate permanent DDoS protection improvements • Update runbooks with new attack signatures and countermeasures • Conduct service availability post-mortem with affected business units	Post-attack: 1 – 4 hrs

3.3 Roles and Responsibilities

Role	Responsibility	Contact
Incident Commander	Coordinates cross-team response; escalates to executive leadership; manages SLA	<i>CISO / IT Director</i>
Network Operations Lead	Analyzes traffic; implements network-level mitigations; ISP coordination	<i>Network Operations Center (NOC)</i>
DDoS Mitigation Specialist	Activates and tunes scrubbing/CDN service; manages mitigation profile	<i>NOC / Cloud Security Team</i>
Application Security Lead	Implements WAF rules; manages CDN and load balancer configuration	<i>Application Security / DevOps</i>
Cloud/Infrastructure Lead	Scales compute resources; manages auto-scaling and CDN failover	<i>Cloud Infrastructure Team</i>
ISP/CDN Liaison	Coordinates upstream scrubbing; manages ISP blackholing if needed	<i>Network Operations</i>
Communications Lead	Prepares customer-facing status page updates; stakeholder briefings	<i>Corporate Communications</i>

Business Continuity Lead	Activates BCP if critical services are unavailable beyond SLA thresholds	<i>Risk Management</i>
---------------------------------	--	------------------------

3.4 Communication Strategy

During Active Attack — Communication Protocol

Timeframe	Audience	Channel	Message
0 – 10 min	NOC, IR Team	Phone / Slack	DDoS confirmed; mitigation activation initiated
10 – 30 min	CISO, IT Director	Phone	Attack type/scale; services affected; mitigation status
30 min	Business Unit Heads	Email / Teams	Service degradation notice; expected resolution timeline
30 – 60 min	Customer Status Page	Status Page (statuspage.io)	Investigating: We are aware of connectivity issues and are actively working to restore service
Every 30 min	All stakeholders	Status Updates	Progress updates on mitigation and service restoration
Post-resolution	Customers, Partners	Email / Status Page	Full resolution notice; summary of impact and corrective measures

3.5 Success Metrics

Metric	Target / Threshold	Owner
Time to Detection	< 5 minutes via automated monitoring	<i>NOC Lead</i>
Time to Mitigation Activation	< 15 minutes from detection	<i>DDoS Mitigation Specialist</i>
Service Restoration Time (MTTR)	< 60 minutes for critical services	<i>Incident Commander</i>
False positive mitigation rate	< 1% legitimate traffic blocked	<i>Application Security</i>
Customer communication timeliness	Status page updated within 30 minutes	<i>Communications Lead</i>
Attack traffic scrubbing rate	> 99% of attack traffic mitigated	<i>NOC / ISP</i>
Post-incident hardening completion	100% of recommended controls within 72 hours	<i>Network Operations</i>

Design Rationale & Benefits

4.1 Design Philosophy

Each playbook is designed following three core principles: speed (clear triggers and immediate actions minimize dwell time), precision (role-based accountability eliminates ambiguity during high-stress incidents), and adaptability (phase-based structure scales to incidents of varying severity).

The playbooks are aligned to the NIST SP 800-61r2 Incident Response Lifecycle and incorporate elements of the MITRE ATT&CK framework for threat actor behavior mapping, enabling teams to anticipate adversary moves rather than react to them.

4.2 Key Design Choices

Tiered Severity Classification

Each playbook defines a default severity level, but all include escalation criteria. This prevents both under-response (treating a critical breach as routine) and over-response (triggering full crisis protocols for a low-impact probe). Severity drives resource allocation, communication scope, and escalation chains.

Phase-Based Response with Time Targets

Explicit time targets for each phase create accountability and enable performance measurement. Without time targets, incidents often suffer from undefined timelines and responder uncertainty. The phases (Detect, Contain, Eradicate, Recover) map directly to NIST guidance while remaining operationally practical.

RACI-Aligned Role Definitions

Each playbook defines roles without over-specifying individuals, making playbooks resilient to personnel changes. The role structure ensures clear ownership across detection, technical response, communications, and compliance — the four pillars of effective incident response.

Communication Matrix Design

Communication failure is among the most common causes of incident response breakdown. Each playbook's communication matrix specifies audience, channel, timing, and message content — removing ambiguity and ensuring that the right stakeholders receive the right information at the right time, preventing both information vacuums and premature disclosure.

4.3 Expected Organizational Benefits

Benefit	Expected Outcome
Reduced MTTD & MTTR	Automated detection triggers and pre-defined response steps cut average response time by 40-60% vs. ad hoc response
Regulatory Compliance	Defined notification timelines and evidence preservation support GDPR, HIPAA, PCI-DSS, and SEC compliance
Reduced Incident Cost	Faster containment limits data exposure, system damage, and business downtime — reducing average incident cost

Improved Staff Readiness	Playbooks serve as training materials for tabletop exercises and simulations, building team muscle memory
Consistent Decision-Making	Pre-approved decision frameworks (e.g., ransom payment criteria) remove decision paralysis during active incidents
Continuous Improvement	Post-incident review template creates a feedback loop, driving iterative playbook refinement after every incident
Stakeholder Confidence	Demonstrated preparedness reassures customers, regulators, and insurers of organizational security maturity

Post-Incident Review Template

Complete this template within 5 business days following closure of any security incident. This review captures lessons learned and drives continuous improvement.

Section 1: Incident Overview

Incident ID	
Incident Type	Phishing / Ransomware / DDoS / Other: _____
Severity Level	Critical / High / Medium / Low
Date Detected	
Date Resolved	
Total Duration	
Incident Commander	
Report Prepared By	

Section 2: Timeline of Events

Date/Time	Event	Details / Actions Taken

Section 3: Impact Assessment

Systems / Assets Affected:

Number of Users Affected:

Data Compromised (type and volume):

Estimated Business Impact / Downtime:

Regulatory / Legal Implications:

Section 4: Root Cause Analysis

NOTE
Identify the root cause(s) that allowed this incident to occur. Use the 5-Whys technique or fishbone diagram as appropriate.

Primary Root Cause:

Contributing Factors:

Attack Vector / Entry Point:

Section 5: Response Evaluation

Evaluation Criterion	Rating (1-5)	Comments
Speed of Detection		
Effectiveness of Containment		
Quality of Communication		
Eradication Completeness		
Recovery Speed		
Stakeholder Coordination		
Documentation Quality		

Section 6: Lessons Learned

What went well?

What could have been done better?

Gaps in tools, processes, or training identified:

Section 7: Corrective Action Plan

Action Item	Owner	Due Date	Status
			Open / In Progress / Closed
			Open / In Progress / Closed
			Open / In Progress / Closed
			Open / In Progress / Closed
			Open / In Progress / Closed

Section 8: Playbook Update Recommendations

Which playbook sections require updates?

Proposed changes to detection criteria:

Proposed changes to response steps:

Training or awareness actions needed:

Section 9: Sign-Off

Role	Name & Signature	Date
Incident Commander		
CISO / Security Manager		
Legal / Compliance		
Communications Lead		

Appendix: Quick Reference Cards

A. Phishing — First 30 Minutes Checklist

7. User reports suspicious email → log ticket in IR system
8. Retrieve email headers and analyze sender, SPF/DKIM/DMARC
9. Check all email logs for same sender → identify all recipients
10. Query URLs in VirusTotal / sandbox → classify as malicious or benign
11. If malicious → quarantine email from all mailboxes immediately
12. Check for credential input → reset password and enforce MFA
13. Notify Incident Commander → escalate if data access detected

B. Ransomware — Immediate Actions (First 15 Minutes)

STOP — ISOLATE FIRST

Before any investigation, physically or logically isolate affected systems. Every second of continued network connectivity allows further encryption and lateral movement.

14. ISOLATE: Disconnect affected host from network (disable NIC or VLAN)
15. DO NOT reboot infected systems — memory evidence will be lost
16. Take memory and disk image of patient zero
17. Alert Backup Team: verify backup integrity immediately
18. Check lateral movement scope: which systems are affected?
19. Notify CISO and convene war room
20. Contact cyber insurance carrier

C. DDoS — First 10 Minutes Checklist

21. Confirm DDoS via network monitoring dashboard or ISP alert
22. Identify attack type: volumetric / protocol / application layer
23. Identify targeted services and current availability status
24. Activate DDoS mitigation service (Cloudflare / Akamai / AWS Shield)
25. Contact ISP: request upstream scrubbing or black hole routing
26. Enable WAF rate limiting for L7 attacks
27. Update status page with initial investigation message

D. Useful Tools & Resources

Tool / Resource	Purpose	URL
ID Ransomware	Ransomware family identification	id-ransomware.malwarehunterteam.com
VirusTotal	URL/file/IP threat intelligence	virustotal.com
Any.run	Interactive malware sandbox	any.run
Shodan	Internet exposure scanning	shodan.io
CISA Advisories	Threat intelligence and alerts	cisa.gov/uscert/ncas/alerts

Have I Been Pwned	Credential breach checking	haveibeenpwned.com
NIST SP 800-61r2	IR lifecycle framework guidance	nvlpubs.nist.gov
MITRE ATT&CK	Adversary tactic/technique mapping	attack.mitre.org

DOCUMENT CLASSIFICATION: CONFIDENTIAL | FOR INTERNAL USE ONLY | Review Annually or After Any Major Incident